

ECOM EXPERTS

ShopShield AI — Conector de auditoría de seguridad

Manual de usuario e instalación

ecom_shopshield 1.0.2 · 08/09/2026

Contenido

1. Qué hace y para quién

2. Compatibilidad

3. Instalación

4. Configuración

Cabecera

Conexión SaaS

Comportamiento

5. Cómo se usa, día a día

5.1 Darse de alta en el servicio

5.2 Lanzar una auditoría

5.3 Ver los resultados

5.4 Cómo se comunica con el servicio (por si hay que abrir el cortafuegos)

6. Qué ve el cliente en la tienda

7. Preguntas frecuentes y problemas

8. Ficha técnica

1. Qué hace y para quién

ShopShield AI es un servicio de auditoría de seguridad con inteligencia artificial que revisa el código de una tienda online en busca de vulnerabilidades: inyecciones SQL, ficheros que ejecutan código remoto, rutas que permiten leer ficheros del servidor, puertas traseras dejadas por módulos de terceros, etc. El servicio vive en <https://vigia.gmartos.es> y lo opera Ecom Experts.

Este módulo (`ecom_shopshield`) es **el agente que se instala en la tienda del cliente**. Su único trabajo es recoger el código de la tienda, enviarlo al servicio por lotes y enseñar en pantalla, en tiempo real, cómo va la subida y el análisis. Los resultados (la lista de hallazgos, con su gravedad y su explicación) **no se muestran en el módulo**: se consultan en el panel del servicio, en la cuenta del cliente.

Le sirve a cualquier tienda PrestaShop 8 o 9 que quiera saber si su núcleo, sus módulos o su tema tienen agujeros de seguridad sin tener que contratar una auditoría manual. La tienda no necesita instalar nada más: solo el módulo y una clave de API que se genera en la cuenta del servicio.

Qué recoge de la tienda: solo ficheros de código (`.php`, `.phtml`, `.inc`, `.module`, `.tpl`, `.twig`, `.js`, `.mjs`, `.css`, `.scss`, `.sql`, `.xml`, `.json`, `.yaml`, `.yml`, `.html`, `.htm`) de hasta 256 KB cada uno. **Nunca** envía imágenes, ficheros `.zip`, `.log`, `.txt`, `.pdf`, copias de seguridad, ni las carpetas `img/`, `upload/`, `download/`, `var/cache/`, `var/logs/`, `vendor/`, `node_modules/`, `translations/`, `mails/`, `admin-dev/`, `install-dev/` ni los minificados `.min.js` / `.min.css`. **No envía la base de datos** ni datos de clientes o pedidos. Sí envía el contenido de los ficheros de código, incluido `config/settings.inc.php` o `app/config/parameters.php` cuando el ámbito elegido los incluye (ámbito «Solo Core PS» y «Todo»): conviene saberlo antes de lanzar la auditoría.

A qué servicio lo manda: a la URL configurada (por defecto <https://vigia.gmartos.es>), por HTTPS con verificación de certificado, autenticándose con la clave de API de la cuenta (`Authorization: Bearer <clave>`). El servicio está en marcha: en el momento de escribir este manual respondía en <https://vigia.gmartos.es/api/v1/...> y rechazaba las peticiones sin clave con `unauthorized`.

2. Compatibilidad

Requisito	Valor
PrestaShop	8.0.0 a 9.x (<code>ps_versions_compliancy</code> min 8.0.0, max 9.99.99). Probado en 9.1.1.
PHP	7.4 o superior (usa tipos escalares y <code>??</code>). Necesita la extensión cURL con soporte SSL.
Multitienda	La configuración es por tienda (<code>Configuration::get</code> / <code>updateValue</code>) pero la auditoría recorre el sistema de ficheros completo , que es común a todas las tiendas de la instalación. En multitienda basta con configurarlo en una.
Idiomas	La pantalla de administración está escrita directamente en castellano (HTML en el PHP, sin ficheros <code>.xlf</code>). No hay textos en el front.
Dependencias	Ninguna librería externa. Sin Composer. Necesita una cuenta en https://vigia.gmartos.es y una clave de API.
Servidor	Para ver el registro en vivo el servidor no debe almacenar en búfer la respuesta (el módulo manda las cabeceras <code>X-Accel-Buffering: no</code> y desactiva gzip para ese flujo). Si hay un proxy o CDN delante que sí lo hace, la barra avanza a saltos pero la auditoría se completa igual.

Versión del módulo: **1.0.2**. Se instala sin errores en PrestaShop 9.1.1 (comprobado en la tienda de pruebas local).

3. Instalación

1. Subir la carpeta `ecom_shopshield` a `modules/` (o el ZIP desde *Módulos* → *Subir un módulo*).
2. Instalar desde el gestor de módulos. La instalación: - crea la tabla `ps_ecom_shopshield_scans` (histórico local de envíos); - crea las claves de configuración `ECOM_SHOPSHIELD_API_URL` (con el valor `https://vigia.gmartos.es`), `ECOM_SHOPSHIELD_API_KEY` (vacía) y `ECOM_SHOPSHIELD_AUTO_SCAN` (0); - **no registra ningún hook** ni añade pestañas al menú: se accede desde *Módulos* → *Gestor de módulos* → *ShopShield AI* → *Configurar*.
3. Entrar en *Configurar*, pegar la clave de API y guardar.

Cada vez que se abre la pantalla de configuración el módulo ejecuta `addnewfeatures()`, que vuelve a lanzar el `CREATE TABLE IF NOT EXISTS`: si la tabla se hubiera borrado, se recrea sola. No hay carpeta `upgrade/`.

Al desinstalar se borra la tabla `ecom_shopshield_scans` y las cinco claves de configuración (URL, clave, auto-scan, fecha y UUID de la última auditoría). No queda nada en la tienda. Los envíos ya realizados siguen en el servicio.

4. Configuración

La pantalla es un único panel (no usa HelperForm) con cuatro zonas: cabecera de estado, panel de auditoría, formulario de conexión e historial local.

Pagina 5 de 9



Cabecera

Muestra la versión del módulo, el estado • **Conectado** / • **Sin configurar** (conectado significa únicamente que hay URL y clave guardadas; no hace ninguna llamada al servicio para comprobarlo), la URL del servicio y, si ya se ha lanzado alguna, la fecha de la última auditoría.

Conexión SaaS

Campo	Efecto
URL del SaaS	Dirección del servicio. Por defecto <code>https://vigia.gmartos.es</code> . Se valida como URL al guardar; si no lo es, sale el aviso «URL del SaaS no válida» y no se guarda nada. Solo hay que cambiarla si Ecom Experts indica otra instancia.
API Key	Clave de la cuenta del cliente en el servicio, con el formato <code>ssh_XXXXXX_XXXXXXXXXXXXXXXXXX</code> . Se genera en <i>tu cuenta</i> → <i>API Keys</i> del panel del servicio (el enlace «General en tu cuenta → API Keys» de la propia pantalla lleva a <code><URL>/account/apikeys</code>). Sin clave el botón «Auditar ahora» queda desactivado y aparece el aviso «Configura URL y API Key primero».

Comportamiento

Opción	Efecto
Auto-scan diario por cron	Guarda la clave <code>ECOM_SHOPSHIELD_AUTO_SCAN</code> a 1. En la versión 1.0.2 esta casilla no tiene ningún efecto todavía: el módulo no trae tarea cron, ni controlador que la lea, ni URL que llamar desde el planificador del servidor. Está preparada para una versión futura. Las auditorías se lanzan a mano desde el botón.

El texto de esa tarjeta habla de auditorías «incrementales» y «chunks de 30 ficheros»: en la 1.0.2 la subida es siempre **completa** (modo `full`, todos los ficheros del ámbito elegido) y por lotes de **15 ficheros**.

Guardar configuración guarda los tres valores a la vez y muestra «✓ Configuración guardada correctamente». Los enlaces «Ir a mi panel SaaS» (`<URL>/account`) y «Ver resultados» (`<URL>/account/scans`) abren el servicio en otra pestaña.

5. Cómo se usa, día a día

5.1 Darse de alta en el servicio

1. Crear una cuenta en `https://vigia.gmartos.es` (el alta se hace en el servicio, no en el módulo).
2. En la cuenta, entrar en *API Keys* (`/account/apikeys`) y generar una clave para esta tienda.
3. Pegar la clave en el campo **API Key** del módulo y pulsar **Guardar configuración**. La cabecera pasa a • **Conectado** y el botón **Auditar ahora** se activa.

5.2 Lanzar una auditoría

1. Elegir **qué auditar** con las cuatro tarjetas del panel:

Ámbito	Carpetas que recoge	Tiempo orientativo (lo indica la pantalla)
 Solo Core PS	<code>classes/</code> , <code>controllers/</code> , <code>override/</code> , <code>config/</code>	5–20 min
 Solo Módulos	<code>modules/</code>	30 min – 2 h
 Solo Theme	<code>themes/</code>	10–30 min
 Todo	toda la raíz de la tienda, incluido <code>src/</code>	2–6 horas

En «Solo Core PS» se deja fuera a propósito la carpeta `src/` (el framework de PrestaShop: `src/Core` , `src/Adapter` , `src/PrestaShopBundle`), porque el cliente no puede corregir ese código y genera muchos falsos positivos. En «Todo» sí se incluye.

2. Pulsar  **Auditar ahora**. Aparece la barra de progreso y un registro negro con las líneas del proceso, en este orden: - «Iniciando auditoría — PrestaShop X · scope: CORE» y el recordatorio de qué extensiones se envían; - «Encontrados N ficheros válidos»; - «Creando scan en el SaaS...» → «Scan creado: ». En este momento se apunta la fila en el historial local con estado `uploading` ; - «Chunk 1/M (15 ficheros)...» → «Chunk 1/M OK (15/N)», y así hasta el último. Cada lote lleva el contenido de los ficheros en base64 y un manifiesto con la ruta, el SHA-256 y el tamaño de cada uno. Si un lote falla se reintenta hasta **3 veces** con espera de 2, 4 y 8 segundos; si sigue fallando la subida se detiene y hay que volver a pulsar el botón; - «Cerrando scan en SaaS...» y «✓ Subida completada. N ficheros, X KB». La fila local pasa a `sent` ; - « Esperando auditoría de los agentes Claude...». A partir de aquí el módulo consulta el estado al servicio cada 5 segundos y va escribiendo el mensaje de progreso que devuelve el análisis, moviendo la barra según los ficheros ya analizados; - al terminar: «✓ Auditoría completada» y el recuento **Críticos / Altos / Medios / Bajos**, con el aviso de que el detalle está en vigia.gmartos.es/account/findings .
3. Si el análisis tarda más de **25 minutos**, el registro avisa de que puede cerrarse la ventana: el análisis sigue en el servicio y el resultado se consulta allí más tarde.

Cancelar () solo cierra la conexión del navegador con el flujo de progreso: si la subida ya había empezado, el servidor puede terminar el lote en curso y el servicio conserva lo recibido.

Al recargar la pantalla, la auditoría aparece en **Últimas auditorías enviadas (local)** con los ocho primeros caracteres de su UUID, el modo, ficheros enviados / encontrados, KB subidos, estado (`uploading` , `sent`) y fecha, y un enlace «Ver» al panel del servicio. Se muestran las 10 últimas.

5.3 Ver los resultados

En el módulo solo se ve el recuento final. La lista de hallazgos, el fichero y la línea afectados, la explicación y la recomendación se consultan en el panel del servicio: <https://vigia.gmartos.es/account/findings> (o [/account/scans](https://vigia.gmartos.es/account/scans) para la lista de auditorías).

5.4 Cómo se comunica con el servicio (por si hay que abrir el cortafuegos)

Todas las llamadas salen **desde el servidor de la tienda** hacia la URL configurada, por HTTPS, con `Authorization: Bearer <clave>` y las cabeceras `X-Agent-Type: ecom_shopshield` y `X-Agent-Version :`

Paso	Petición
Crear auditoría	POST /api/v1/scan con <code>scan_mode</code> , <code>trigger</code> , <code>platform=prestashop</code> , <code>agent_type</code> , <code>agent_version</code> , <code>ps_version</code>
Subir lote	POST /api/v1/scan/<uuid>/chunk con <code>chunk_index</code> , <code>chunk_total</code> , <code>manifest</code> , <code>bundle</code>
Cerrar	POST /api/v1/scan/<uuid>/finish
Consultar estado	GET /api/v1/scan/<uuid>
Versión del agente	GET /api/v1/version/module_prestashop (disponible en el cliente, no se usa desde la pantalla)

Tiempos de espera: 10 s para conectar, 90 s por petición de subida, 30 s por consulta.

El navegador del administrador, por su parte, se conecta a `modules/ecom_shopshield/ajax_direct.php?eid=<empleado>&tk=<token>&action=stream&scope=...` para recibir el registro en vivo (Server-Sent Events). El token es un SHA-256 del id del empleado, la `_COOKIE_KEY_` de la tienda y la fecha del día, así que caduca a medianoche; si no coincide se acepta la cookie `psAdmin`, y si tampoco, responde 403.

6. Qué ve el cliente en la tienda

Nada. El módulo no registra hooks ni añade nada al front. El controlador `controllers/front/ajax.php` existe solo como ruta alternativa para el registro en vivo y exige sesión de empleado; un visitante recibe `403 forbidden`.

7. Preguntas frecuentes y problemas

El botón «Auditar ahora» está gris. Falta la URL o la clave de API. Rellenarlas y guardar.

«Error creando scan: unauthorized». La clave de API no es válida o se ha revocado en el servicio. Generar otra en `/account/apikeys` y guardarla.

«Error creando scan: curl: ...» o «http_0». El servidor de la tienda no llega a `vigia.gmartos.es`: cortafuegos de salida, DNS o certificado. Comprobar desde el servidor con `curl -I https://vigia.gmartos.es`. El módulo verifica el certificado SSL; si el servidor tiene un paquete de CA obsoleto la conexión falla con un error de certificado.

«Conexión SSE perdida» nada más pulsar. El servidor web corta la respuesta larga (`max_execution_time` o `FastCGI` con tiempo límite, o un proxy que espera la respuesta completa). El módulo pone `set_time_limit(0)`, pero un límite en PHP-FPM o en el proxy manda más. Mientras tanto la subida puede haber seguido en el servidor: mirar el historial local y el panel del servicio antes de repetir.

«Chunk N falló ... Reintentando». Lote demasiado pesado para la conexión o el servicio saturado; se reintentará tres veces solo. Si aborta, volver a pulsar «Auditar ahora» (se crea una auditoría nueva; el servicio no reanuda la anterior en esta versión, aunque el registro diga «se reanudará desde aquí»).

Ha pasado media hora y no termina. A los 25 minutos el módulo deja de esperar, pero el análisis sigue en el servicio. Consultar `/account/findings` más tarde.

He activado «Auto-scan diario» y no pasa nada por la noche. Es lo esperado en la 1.0.2: no existe todavía la tarea cron (ver sección 4).

¿**Envía contraseñas?** Envía el contenido de los ficheros de código del ámbito elegido. En «Solo Core PS» y «Todo» entra `config/`, donde PrestaShop guarda las credenciales de la base de datos (`app/config/parameters.php` en 8/9 no está en `config/`, pero `config/` sí contiene `settings.inc.php` en instalaciones antiguas). Si eso no es aceptable, usar «Solo Módulos» o «Solo Theme».

La pantalla dice «Conectado» pero nunca he probado la clave. «Conectado» solo indica que los dos campos están rellenos; la primera comprobación real es al pulsar «Auditar ahora».

8. Ficha técnica

Ficheros

Fichero	Función
<code>ecom_shopshield.php</code>	Clase <code>Ecom_Shopshield</code> : instalación, pantalla de configuración (HTML propio), <code>triggerScan()</code> (envío síncrono sin registro en vivo; no se usa desde la pantalla).
<code>ajax_direct.php</code>	Punto de entrada directo que arranca PrestaShop (<code>config/config.inc.php</code>), valida el token o la cookie de empleado y delega en el runner. Es el que usa la pantalla.
<code>classes/Ecom_ShopshieldClient.php</code>	Cliente HTTP (cURL) del servicio: <code>createScan</code> , <code>uploadChunk</code> , <code>finishScan</code> , <code>getScanStatus</code> , <code>checkVersion</code> .
<code>classes/Ecom_ShopshieldRunner.php</code>	Recorrido de ficheros por ámbito, envío por lotes con reintentos, flujo SSE y sondeo del resultado.
<code>controllers/front/ajax.php</code>	<code>Ecom_shopshieldAjaxModuleFrontController</code> : misma lógica vía dispatcher (? <code>fc=module&module=ecom_shopshield&controller=ajax</code>), sin reintentos ni sondeo. Ruta alternativa.
<code>controllers/admin/AdminEcomShopshieldAjaxController.php</code>	Versión anterior del flujo como controlador admin. No tiene pestaña registrada y la pantalla no lo usa.

Tabla `ecom_shopshield_scans`: `id_scan` , `scan_uuid` (único), `trigger_type` , `scan_mode` , `files_total` , `files_changed` , `bytes_sent` , `status` , `findings_critical` , `findings_high` , `findings_medium` , `findings_low` , `error_message` , `created_at` , `updated_at` . Los contadores de hallazgos existen en la tabla pero en la 1.0.2 no se rellenan (solo se muestran en el registro en vivo).

Claves de configuración (por tienda): `ECOM_SHOPSHIELD_API_URL` , `ECOM_SHOPSHIELD_API_KEY` , `ECOM_SHOPSHIELD_AUTO_SCAN` , `ECOM_SHOPSHIELD_LAST_SCAN_AT` , `ECOM_SHOPSHIELD_LAST_SCAN_UUID` .

Hooks: ninguno. **Pestañas de menú:** ninguna. **Cron:** no existe en la 1.0.2. **Logs:** el módulo no escribe ficheros de registro; el registro en vivo solo se ve en pantalla. **Traducciones:** declara `isUsingNewTranslationSystem()` , pero los textos van fijos en castellano en el HTML.

Constantes del runner: 15 ficheros por lote, 256 KB máximo por fichero, 3 reintentos por lote con espera 2·2ⁿ segundos, sondeo cada 5 s durante 25 min como máximo.